

INCIDENT RESPONSE REPORT

The Planet's Prestige — Email Analysis

Analyst: Mehenni May · Date: 25 February 2026 · Classification: TLP:WHITE · Platform: BTLO

VERDICT
CONFIRMED
MALICIOUS

SEVERITY
MEDIUM

PAYLOAD
SOCIAL
ENGINEERING

STATUS
INVESTIGATION
COMPLETE

01 EXECUTIVE SUMMARY

This report documents the analysis of a targeted phishing email delivered to themajoronearth@gmail.com. The sender's identity was fabricated, the attachment disguised, and the contents concealed through multiple overlapping techniques. This summary is written for management and non-technical stakeholders; full technical detail begins in Section 02.

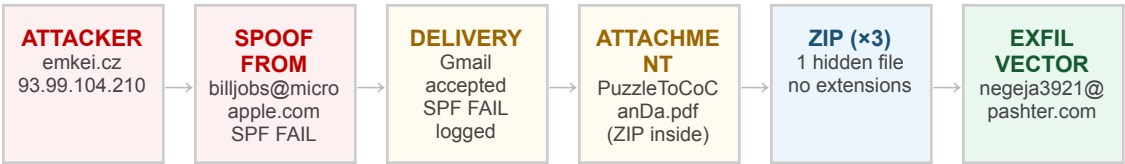
Category	Summary
What happened	A spoofed extortion email was delivered to a Gmail account. The sender identity was fabricated using emkei.cz, a publicly available anonymous mail relay. The email body — encoded in Base64 — contained a demand for financial payment. The attached file was declared as a PDF but was a ZIP archive containing three files: an attacker instruction document, a visual social engineering prop, and a spreadsheet with a hidden encoded location string.
Why it matters	The campaign employed six layered obfuscation techniques: anonymous sender spoofing, SPF failure without enforced DMARC rejection, file format masquerading (ZIP as PDF), a hidden file attribute inside the archive, no-extension file naming, and white-on-white cell concealment in Excel. No single security control would have addressed all six layers simultaneously.
Risk level	MEDIUM. The email was successfully delivered. No malicious executable or auto-running payload was found. The primary risk is social engineering: a non-technical recipient could have disclosed information or initiated a fraudulent payment. Risk remains medium until steganographic analysis of the enclosed JPEG image is complete.
Business impact	A recipient who replied would have communicated directly with the attacker via the attacker-controlled Reply-To domain. A critical attribution error was also identified: the PDF Author metadata field contains 'Pestero Negeja', directly linking the document to the Reply-To address negeja3921@pashter.com. The attacker failed to scrub document metadata before delivery.
What was done	Full email header analysis confirmed SPF failure and relay identity. Sender infrastructure was investigated via WHOIS and DNS. The attachment was decoded and its format confirmed via file signature analysis. All three enclosed files were identified via hex analysis and ExifTool. Concealed spreadsheet data was extracted and Base64-decoded. All findings are supported by screenshots.

Recommended actions	Block 93.99.104.210 and emkei.cz at the email gateway. Block pashter.com. Add the attachment SHA256 to the threat intelligence platform. Conduct steganographic analysis of DaughtersCrown.jpeg. Investigate microapple.com domain ownership. Notify the recipient. Close as confirmed malicious.
----------------------------	---

02 ATTACK FLOW & TIMELINE

2.1 Attack Flow

The diagram maps the end-to-end attack chain. Each node represents a stage at which the attacker made a deliberate obfuscation decision to evade a specific control layer.



The attacker's strategy is cumulative: individually each layer is low-risk and commonly available; combined, they substantially reduce the probability of automated detection at any single control point.

2.2 Timeline of Events

Date / Time	Phase	Event
Jan 25 2021 22:41 PST	Delivery	Attacker sends email via emkei.cz — SPF FAIL logged by Gmail's Authentication-Results header
Jan 25 2021 04:41 UTC	Weaponize	DaughtersCrown file created (JPEG, 19 KB, no extension)
Jan 26 2021 10:27 UTC	Weaponize	Money.xlsx created (17 KB) — Sheet1 white-on-white text written; Sheet3 Base64 payload embedded
Jan 26 2021 11:14 UTC	Weaponize	GoodJobMajor created (PDF, 28 KB, hidden attribute set) — authored last; references the other two files
Feb 25 2026	Triage	Analyst receives .eml sample — BTLO investigation initiated; case BTLO-PLANETS-001 opened
Feb 25 2026	Sec. 03	Email headers analysed — SPF FAIL confirmed, emkei.cz relay identified, From/Reply-To mismatch documented
Feb 25 2026	Sec. 04	Attachment decoded — ZIP magic bytes confirmed (50 4B 03 04); file format masquerade documented
Feb 25 2026	Sec. 05	Hybrid Analysis sandbox run — no malware detected; archive confirmed as social engineering content
Feb 25 2026	Sec. 06	Infrastructure OSINT: emkei.cz WHOIS, pashter.com MX, DMARC absence all documented

Feb 25 2026	Sec. 04	ZIP extracted — GoodJobMajor hidden attribute discovered; all 3 files identified via hex + ExifTool
Feb 25 2026	Sec. 04	Money.xlsx Sheet3 white-on-white Base64 extracted and decoded → 'The Martian Colony, Beside Interplanetary Spaceport.'
Feb 25 2026	Sec. 04	ExifTool on GoodJobMajor.pdf — Author: 'Pestero Negeja' — attribution indicator linking PDF to Reply-To address
Feb 25 2026	Close	All 16 sections documented, IOCs extracted, recommendations issued — investigation complete

03 INITIAL TRIAGE & EMAIL HEADER ANALYSIS

3.1 Triage Summary

Case ID	BTLO-PLANETS-001
Alert source	Email file (.eml) — submitted for analyst review via BTLO challenge
Severity	MEDIUM — spoofed sender, multi-layer obfuscated attachment, social engineering content
Scope	Single email, single recipient — no lateral spread observed
Affected user	themajoronearth@gmail.com (external Gmail account)
Containment	Not required — no malware execution or endpoint compromise confirmed
Initial verdict	Confirmed malicious — spoofed sender, disguised attachment, attacker-controlled infrastructure

3.2 Email Metadata

Date / time (UTC)	Monday, 26 January 2021 06:41:18 UTC (Jan 25 2021 22:41:18 PST)
Message-ID	20210126064118.1993E221F8@localhost
From (claimed)	Bill <billjobs@microapple.com>
Reply-To	negeja3921@pashter.com — different domain from From; inconsistent with declared sender
To	themajoronearth@gmail.com
Subject	A Hope to CoCanDa
Received by	mx.google.com (Gmail infrastructure — smtp id 1993E221F8)
SMTP relay IP	93.99.104.210 — emkei.cz anonymous fake mailer (confirmed)
Content-Type	multipart/mixed (body + attachment)
Attachment name	PuzzleToCoCanDa.pdf — declared PDF, confirmed ZIP archive
Errors-To	billjobs@microapple.com

3.3 Email Authentication

All three standard email authentication mechanisms were evaluated. Their combined failure confirms the sender identity is fabricated and that no policy existed to block delivery.

Protocol	Result	Detail	Impact
SPF	FAIL	93.99.104.210 is not authorised to send for microapple.com	Definitive authentication failure. Explicitly recorded in Authentication-Results header. The stated sender identity is fabricated.
DKIM	ABSENT	No DKIM signature present in headers	Message body integrity cannot be verified. No authorised mail server confirmed.
DMARC	NO POLICY	No DMARC record on microapple.com	Without a DMARC reject/quarantine policy, SPF failure alone does not prevent delivery. Gmail accepted the message despite the authentication failure.

SPF FAIL + No DMARC = Successful Delivery. The header records 'spf=fail (google.com: domain of billjobs@microapple.com does not designate 93.99.104.210 as permitted sender)'. Because microapple.com publishes no DMARC enforcement policy, Gmail delivered the email despite the failure. SPF without DMARC is a well-known gap — organisations that publish only SPF create a false sense of protection.

3.4 From / Reply-To Domain Mismatch

The From domain (microapple.com) and Reply-To domain (pashter.com) are entirely different. This is a classic social engineering technique: the attacker presents a credible From identity while directing all victim replies to an attacker-controlled mailbox.

Header	Value	Assessment
From	billjobs@microapple.com	Spoofed — SPF FAIL, emkei.cz relay. microapple.com did not send this message.
Reply-To	negeja3921@pashter.com	Attacker-controlled receiving address. Any victim reply is captured by pashter.com, bypassing the claimed sender entirely.

3.5 Email Body — Encoding & Content

The email body was transmitted as Base64-encoded plain text. CyberChef decoded it to reveal a social engineering narrative addressed to 'TheMajorOnEarth'. Two embedded clues are forensically significant: a location reference and a visual deception warning.

```
Hi TheMajorOnEarth,  
The abducted CoCanDians are with me including the President's daughter. Dont  
worry. They are safe in a secret location.  
Send me 1 Billion CoCanDs in cash with a spaceship and my autonomous bots  
will safely bring back your citizens.
```

04 STATIC ANALYSIS

Static analysis covers all examination performed without executing code. This section documents file signature identification, format validation, hash verification, metadata extraction, hidden attribute discovery, and data concealment techniques across the attachment and all enclosed files.

4.1 Attachment — File Format Masquerade

The attachment is declared as PuzzleToCoCanDa.pdf with Content-Type: application/pdf. Decoding the raw Base64 and inspecting the first bytes reveals it is a ZIP archive. This is a deliberate file-type masquerade.

Declared filename	PuzzleToCoCanDa.pdf
Declared MIME type	application/pdf — incorrect
Actual file type	ZIP archive — confirmed via magic byte analysis
Magic bytes	50 4B 03 04 (PK ZIP Local File Header signature)
Expected PDF bytes	25 50 44 46 (%PDF) — not present
File size	137 KiB
SHA256	97c6f491cd7901be601c2ef075c39bca5c2f51ef4eeb4524f8b5b52cc8ab62d2
Verification	CyberChef (From Base64 → To Hex) cross-referenced against Gary Kessler File Signatures database

File format confirmed as ZIP, not PDF. Magic bytes 50 4B 03 04 match the PK ZIP Local File Header. A genuine PDF begins with 25 50 44 46 (%PDF) — these bytes are absent. The MIME type declaration is false. This technique is used to bypass email gateways that permit PDFs but restrict ZIP archives.

Figure 2 – CyberChef: Attachment Decoded from Base64 — First Bytes 50 4B 03 04 (ZIP Signature)

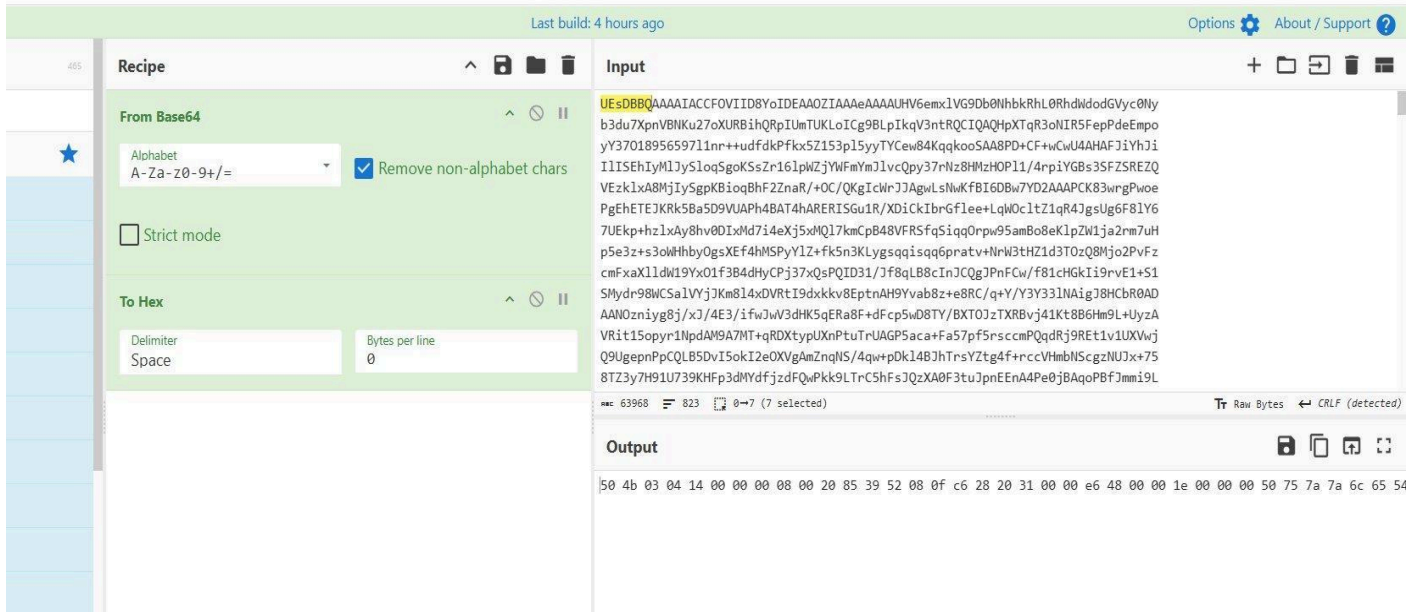


Figure 3 – Gary Kessler File Signatures: 50 4B 03 04 = ZIP Archive (Confirmed)

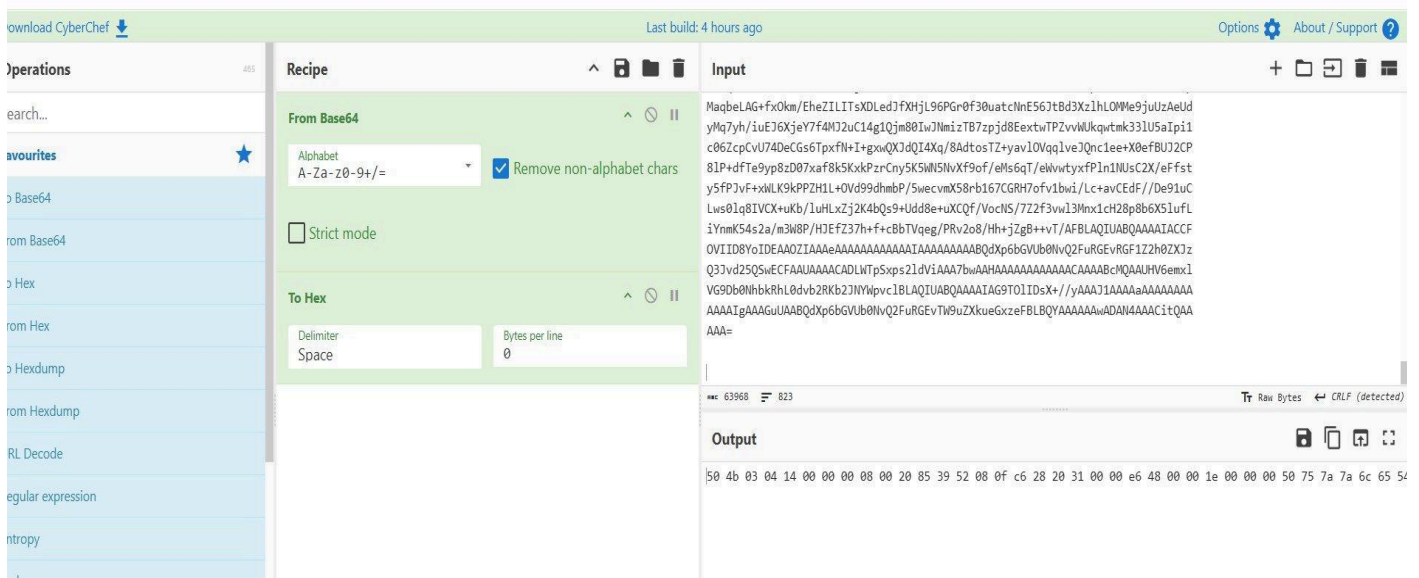
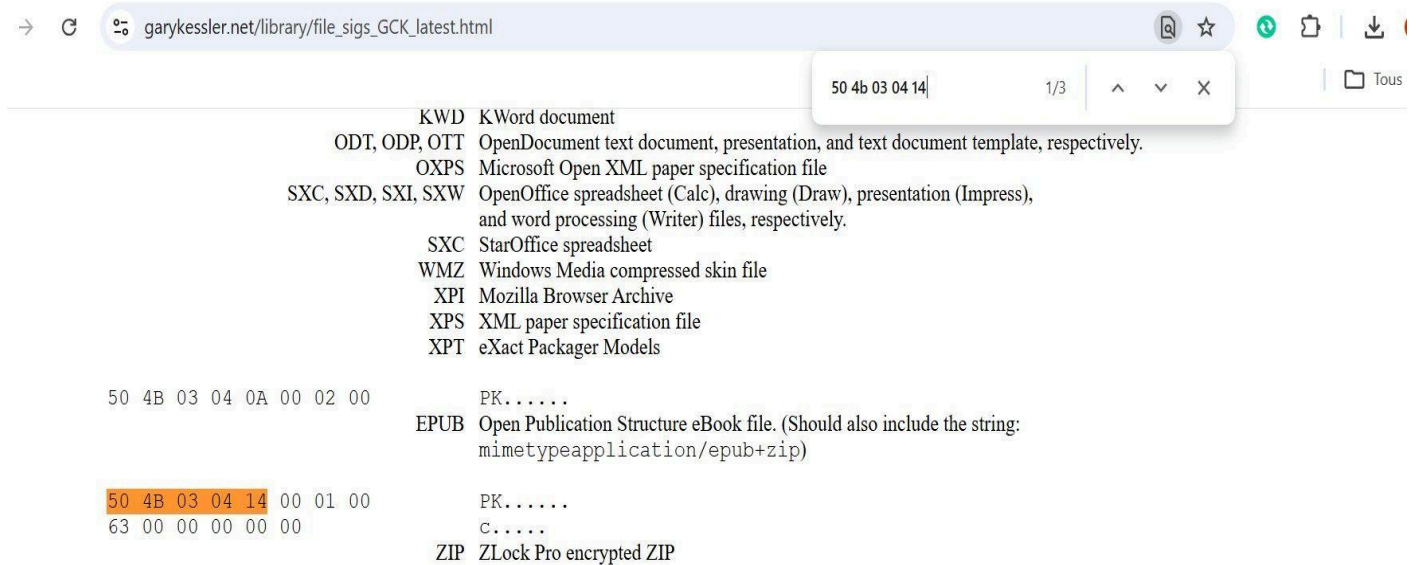


Figure 4 – CyberChef: Attachment Saved as attachment.zip for Extraction



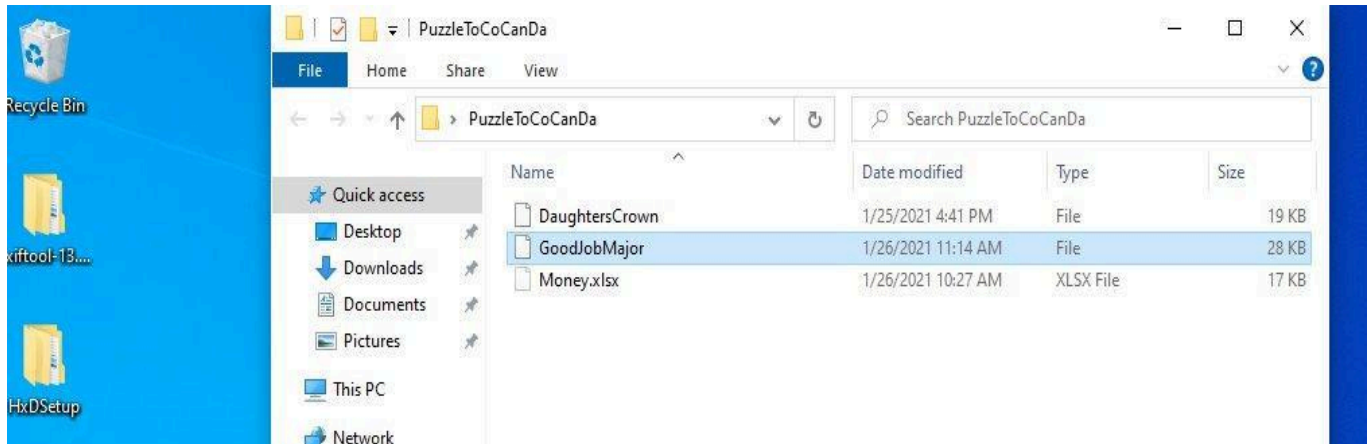
4.2 ZIP Contents — Extraction & Hidden File Discovery

The archive was extracted in a controlled Windows VM. Three files reside inside the PuzzleToCoCanDa/ directory. All three lack file extensions. Enabling 'View → Hidden Items' in Windows Explorer revealed that GoodJobMajor carried a hidden file attribute — invisible to a recipient using default extraction settings.

Filename	Size	Hidden Attribute	True Format (confirmed)
DaughtersCrown	19 KB	No	JPEG image (FF D8 FF E0)
GoodJobMajor	28 KB	YES — hidden	PDF document (25 50 44 46)
Money.xlsx	17 KB	No	Excel spreadsheet (declared extension — hidden content within)

GoodJobMajor was set as a hidden file inside the archive. A recipient extracting without enabling hidden item visibility would find only two files. The hidden document is the attacker's primary instruction note — its concealment is intentional and represents a standalone obfuscation layer separate from the outer file format masquerade.

Figure 5 – Windows Explorer: PuzzleToCoCanDa/ — GoodJobMajor Visible Only After 'Show hidden items' Enabled



4.3 GoodJobMajor — Identification, Content & Metadata

Magic byte analysis in HxD identifies GoodJobMajor as a PDF. The file renders as a single-page instruction note linking all three enclosed files. ExifTool produced a significant attribution finding in the metadata.

File	GoodJobMajor (no extension, hidden attribute)
First 4 bytes	25 50 44 46 (%PDF signature)
Confirmed format	Adobe PDF — version 1.5
Author (ExifTool)	Pestero Negeja
Producer	Skia/PDF m90 (Google Chrome / Chromium print-to-PDF function)
Page count	1
File modified	2021-01-26 11:14:22 +01:00

ATtribution INDICATOR. PDF Author field: 'Pestero Negeja'. Reply-To username: negeja3921. Reply-To domain: pashter.com. 'Negeja' appears in both the document metadata and the email username. 'Pestero' maps to 'pashter' (domain). The attacker created this document while authenticated under this identity and did not scrub metadata before delivery — a direct, evidential link between the file and the attacker's infrastructure.

Producer field 'Skia/PDF m90' indicates generation via Chrome or Chromium's built-in print-to-PDF. This is characteristic of a low-sophistication actor composing content in a browser rather than a dedicated authoring tool — consistent with other indicators of ad-hoc campaign construction.

CoCanDians are Safe.

The proof is in the file named DaughtersCrown
Location to send 1 Billion CoCanDs is in Money.xlsx

This document is the attacker's pivot point: it confirms the narrative, directs the recipient to DaughtersCrown as evidence, and directs them to Money.xlsx for the ransom location — binding all three files into a sequential social engineering chain.

Figure 6 – HxD: GoodJobMajor — Magic Bytes 25 50 44 46 (PDF Signature Confirmed)

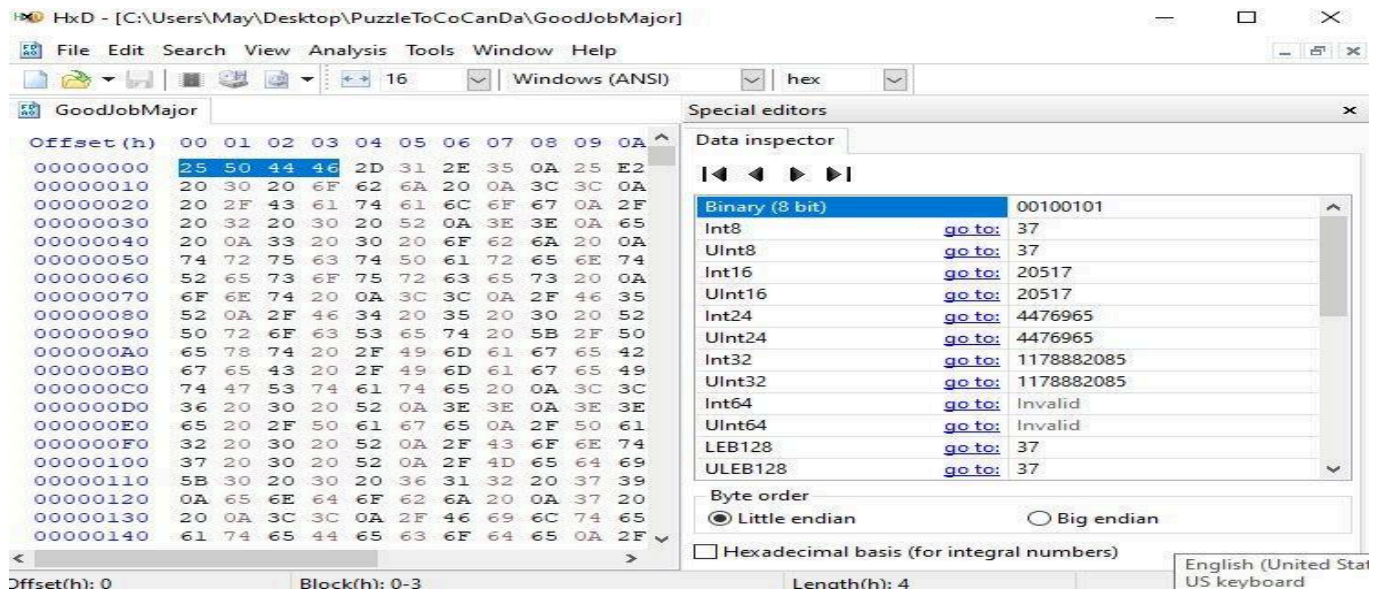


Figure 7 – Gary Kessler DB: 25 50 44 46 = PDF Format (Confirmed)

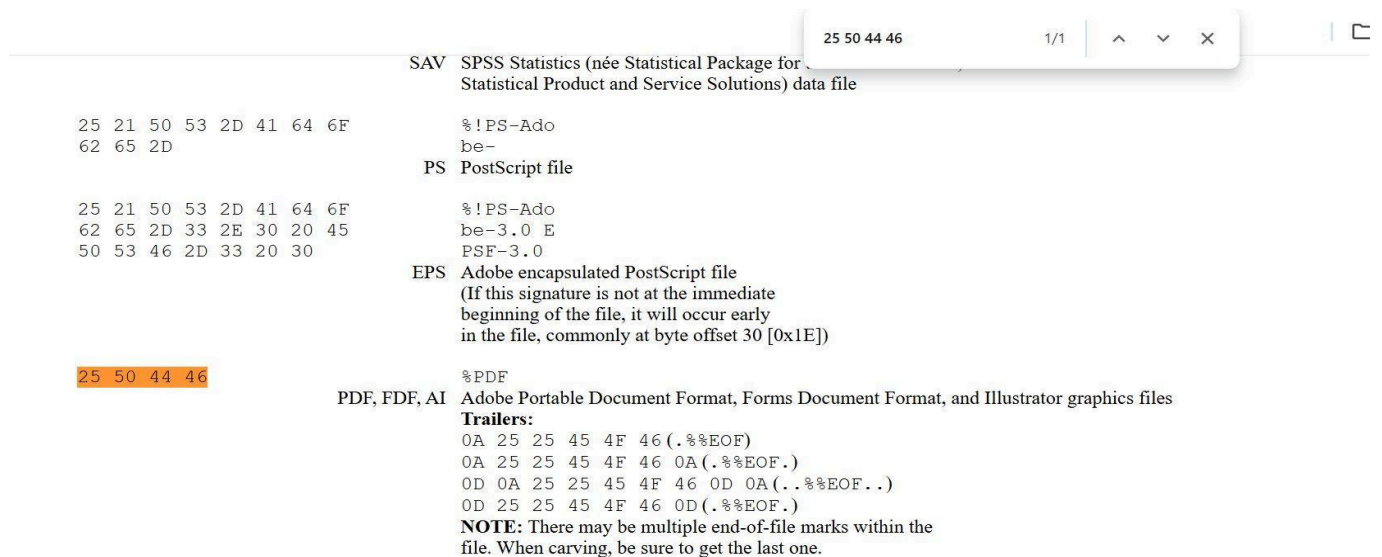
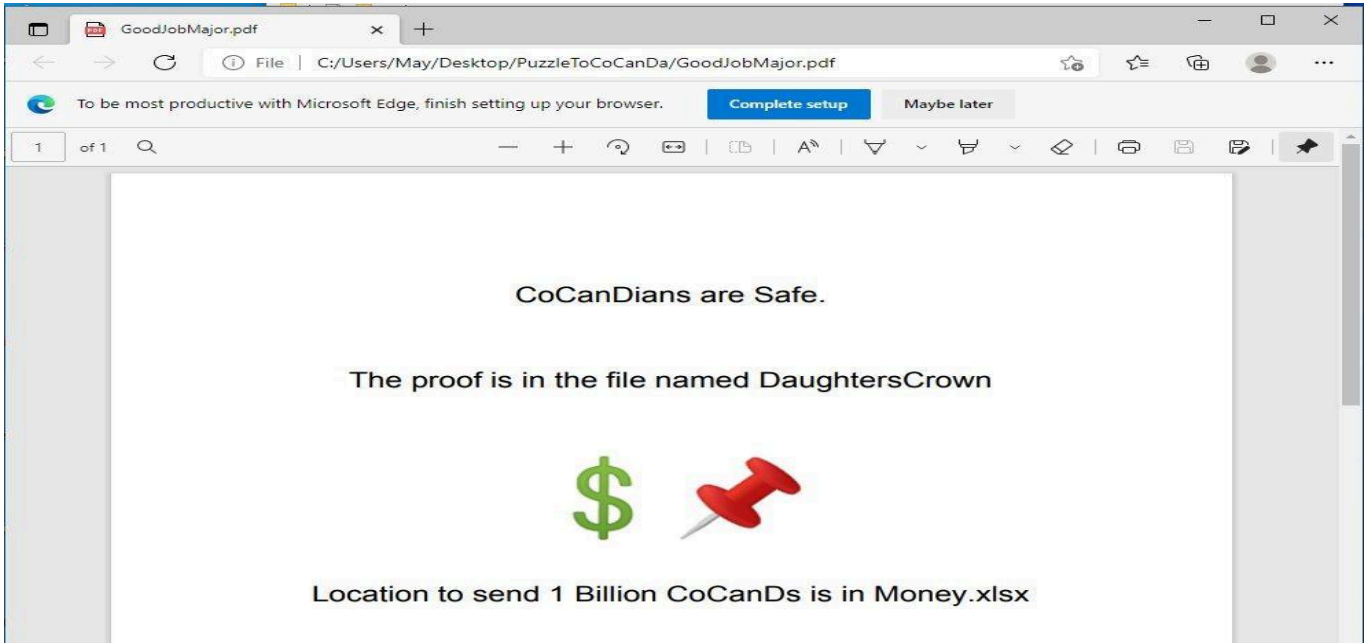


Figure 8 – ExifTool: GoodJobMajor.pdf — Author: 'Pestero Negeja' (Attribution Indicator)

```
C:\Users\May\Desktop\exiftool-13.51_64\exiftool-13.51_64>exiftool GoodJobMajor.pdf
ExifTool Version Number      : 13.51
File Name                    : GoodJobMajor.pdf
Directory                    : .
File Size                    : 28 kB
File Modification Date/Time   : 2021:01:26 11:14:22+01:00
File Access Date/Time        : 2026:02:25 00:56:07+01:00
File Creation Date/Time      : 2026:02:25 00:56:06+01:00
File Permissions              : -rw-rw-rw-
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.5
Linearized                   : No
Author                       : Pestero Negeja
Producer                     : Skia/PDF m90
Page Count                   : 1
```

Figure 9 – GoodJobMajor.pdf Rendered: Attacker Instruction Note — Proof and Location References



4.4 DaughtersCrown — Identification & Metadata

DaughtersCrown has no file extension. Hex analysis confirms it is a JPEG image. ExifTool shows standard encoding with no anomalous fields — no GPS, no device identifier, no software string.

File	DaughtersCrown (no extension)
First 4 bytes	FF D8 FF E0 (JPEG/JFIF SOI + APP0 marker)
Confirmed format	JPEG/JFIF — Baseline DCT, Huffman coding
Dimensions	822 × 435 px (0.358 megapixels)
Resolution	120 × 120 DPI

Colour space	YCbCr (3 components, 4:2:0 subsampling)
EXIF camera data	Absent — no device, GPS, or software metadata fields present
File modified	2021-01-25 16:41:00 +01:00
Role in campaign	Attacker's purported visual proof of life — referenced in GoodJobMajor.pdf as evidence of the hostage claim

The absence of EXIF camera metadata is consistent with an image sourced from the web or generated digitally. The email body hint 'Don't Trust Your Eyes' suggests the possibility of steganographic content embedded within the pixel data. Dedicated steganographic tools (steghide, binwalk, zsteg) are required for verification and are outside the scope of this investigation.

Figure 10 – HxD: DaughtersCrown — Magic Bytes FF D8 FF E0 (JPEG/JFIF Signature)

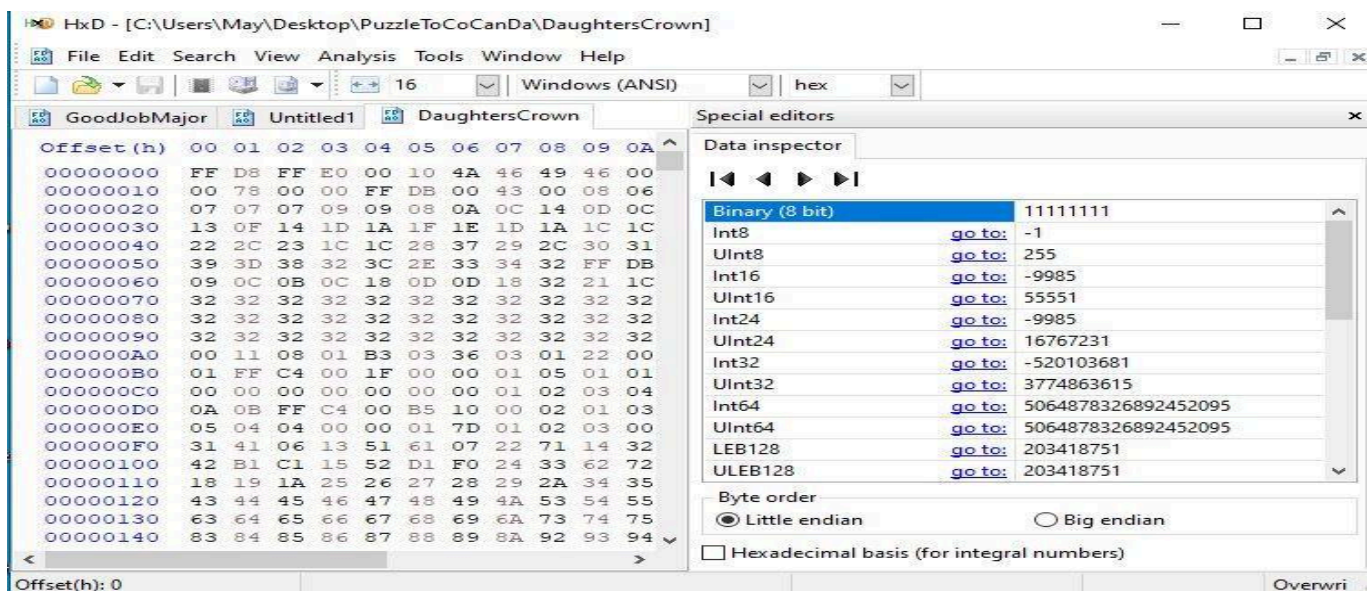


Figure 11 – Gary Kessler DB: FF D8 FF E0 = JPEG/JFIF (Confirmed)



Between the SOI and EOI, JPEG files are composed of *segments*. Segments start with a two-byte *Segment Tag* followed by a two-byte *Segment Length* field and then a zero-terminated string identifier (i.e., a character string followed by a 0x00), as shown below with the JFIF, Exif, and SPIFF segments.

Segment Tags of the form 0x-FF-Ex (where x = 0..F) are referred to as APP0-APP15, and contain application-specific information. The most commonly seen APP segments at the beginning of a JPEG file are APP0 and APP1 although others are also seen. Some additional tags are shown below:

- 0xFF-D8-FF-E0 — [Standard JPEG/JFIF file](#), as shown below.
- 0xFF-D8-FF-E1 — Standard JPEG file with Exif metadata, as shown below.
- 0xFF-D8-FF-E2 — Canon Camera Image File Format (CIFF) JPEG file (formerly used by some EOS and Powershot cameras).
- 0xFF-D8-FF-E8 — [Still Picture Interchange File Format \(SPIFF\)](#), as shown below.

```
FF D8 FF E0 xx xx 4A 46      ýøÿà..JF
49 46 00                    IF.
                             JFIF, JPE, JPEG, JPG
                             JPEG/JFIF graphics file
                             Trailer: FF D9 (ÿÜ)
```

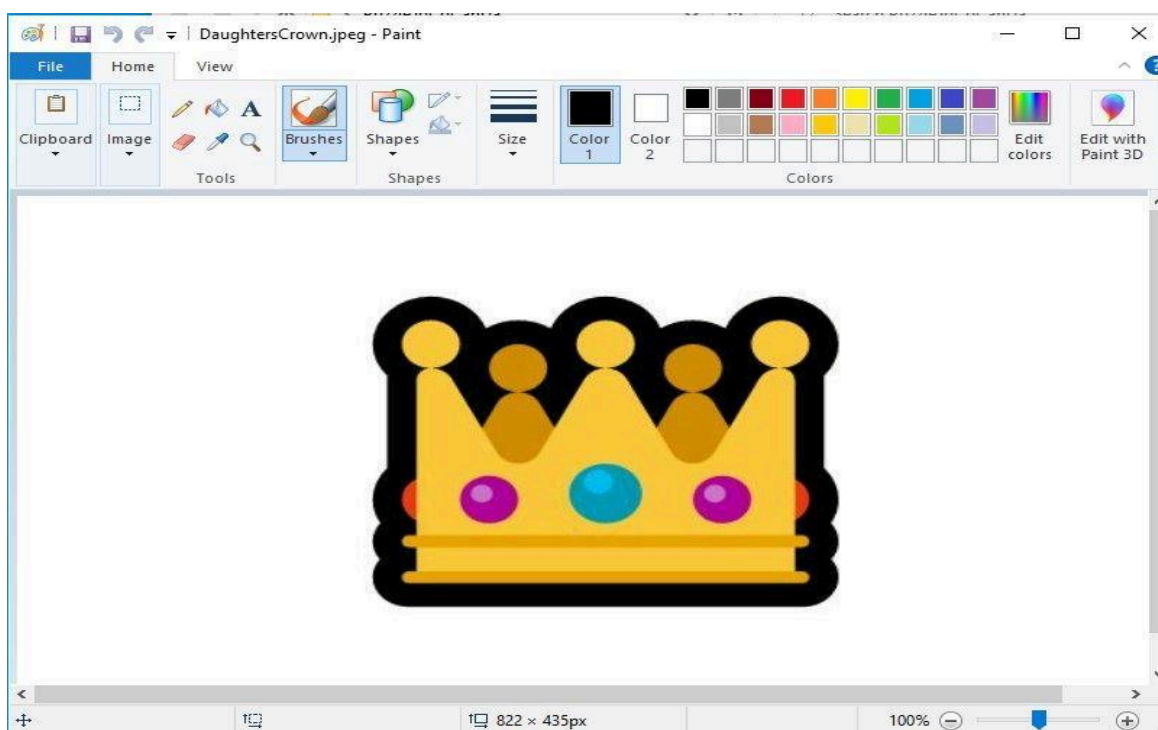
Figure 12 – ExifTool: DaughtersCrown.jpeg — Standard Metadata, No Anomalous Fields


```

C:\Users\May\Desktop\exiftool-13.51_64\exiftool-13.51_64>exiftool DaughtersCrown.jpeg
ExifTool Version Number      : 13.51
File Name                    : DaughtersCrown.jpeg
Directory                   : .
File Size                   : 19 kB
File Modification Date/Time  : 2021:01:25 16:41:00+01:00
File Access Date/Time       : 2026:02:25 00:54:36+01:00
File Creation Date/Time     : 2026:02:25 00:51:43+01:00
File Permissions            : -rw-rw-rw-
File Type                   : JPEG
File Type Extension         : jpg
MIME Type                   : image/jpeg
JFIF Version                : 1.01
Resolution Unit             : inches
X Resolution                : 120
Y Resolution                : 120
Image Width                 : 822
Image Height                : 435
Encoding Process            : Baseline DCT, Huffman coding
Bits Per Sample             : 8
Color Components            : 3
Y Cb Cr Sub Sampling       : YCbCr4:2:0 (2 2)
Image Size                  : 822x435
Megapixels                  : 0.358

```

Figure 13 – DaughtersCrown.jpeg Rendered in Paint (822 × 435 px) — Crown Visual / Proof of Life Prop



4.5 Money.xlsx — Hidden Content Analysis

Money.xlsx is the only file in the archive with a declared extension. Two separate concealment layers were identified: white-on-white formatted text in Sheet1, and a Base64-encoded string in Sheet3 — which appeared entirely empty on initial inspection.

Sheet1 — text revealed after rendering through Aspose online viewer:

```
Cell B3:
```

```
Whatever you have seen or read till now is fake. Our intension was not for
money. It is the beginning of the WAR WITH CoCanDians
Cells A5 / B5:
Location | planet
Cell B8:
Find and come ASAP I'm Waiting!
```

Sheet3 — appeared completely empty. After removing all cell formatting in Google Sheets, a Base64 string was revealed in cell B4:

```
Cell B4 (Sheet3) - concealed via white-on-white formatting:
VGhlIE1hcnRpYW4gQ29sb255LCBCZXNpZGUGSW50ZXJwbGFuZXRhcnkgU3BhY2Vwb3J0Lg==
Base64 Decoded →
The Martian Colony, Beside Interplanetary Spaceport.
```

Concealment method	White font on white background — content invisible until formatting is removed or raw cell data is accessed programmatically
Encoding	Base64
Decoded value	The Martian Colony, Beside Interplanetary Spaceport.
Location chain	Email body '12.8 light-min from sun' → Sheet1 'planet' → Sheet3 Base64 → full location. Mars average distance: ~12.7 light-min. The thematic frame is internally consistent across all evidence layers.

Static analysis complete. Four concealment layers identified and resolved across three files. One attribution indicator found in PDF metadata. The decoded location chain is fully reconstructed. No executable payload exists in any file.

Figure 14 – Money.xlsx Sheet1 (Aspose Viewer): White-on-White Text Revealed

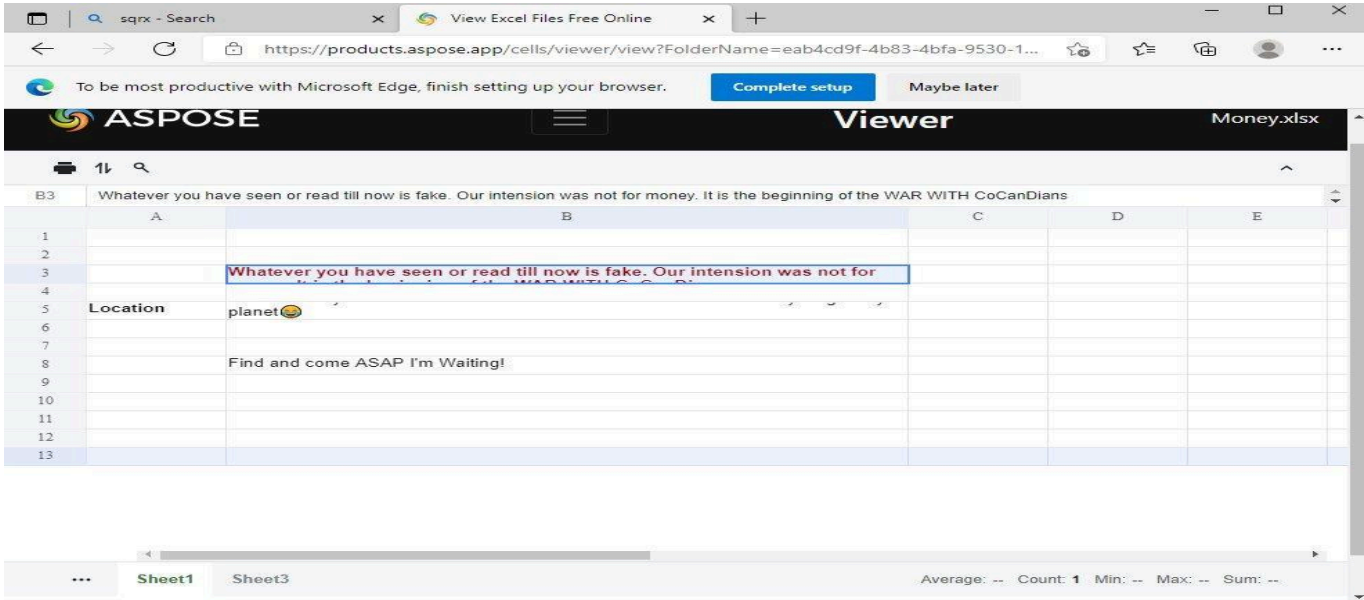
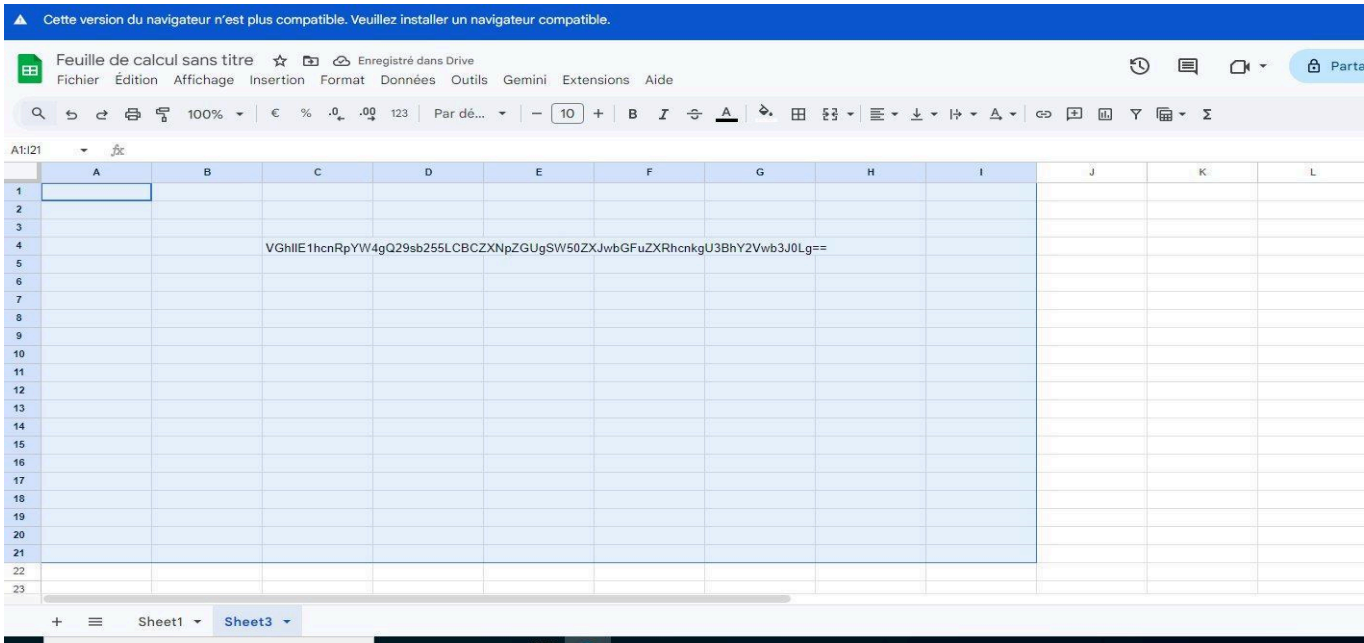


Figure 15 – Google Sheets Sheet3: Hidden Base64 Exposed After All Formatting Removed



05 DYNAMIC ANALYSIS

The ZIP attachment was submitted to Hybrid Analysis (CrowdStrike Falcon Sandbox) for automated behavioural and antivirus analysis. This section is included as standard — ruling out executable payload components not visible through static methods is a required step in any email investigation.

5.1 Sandbox Results

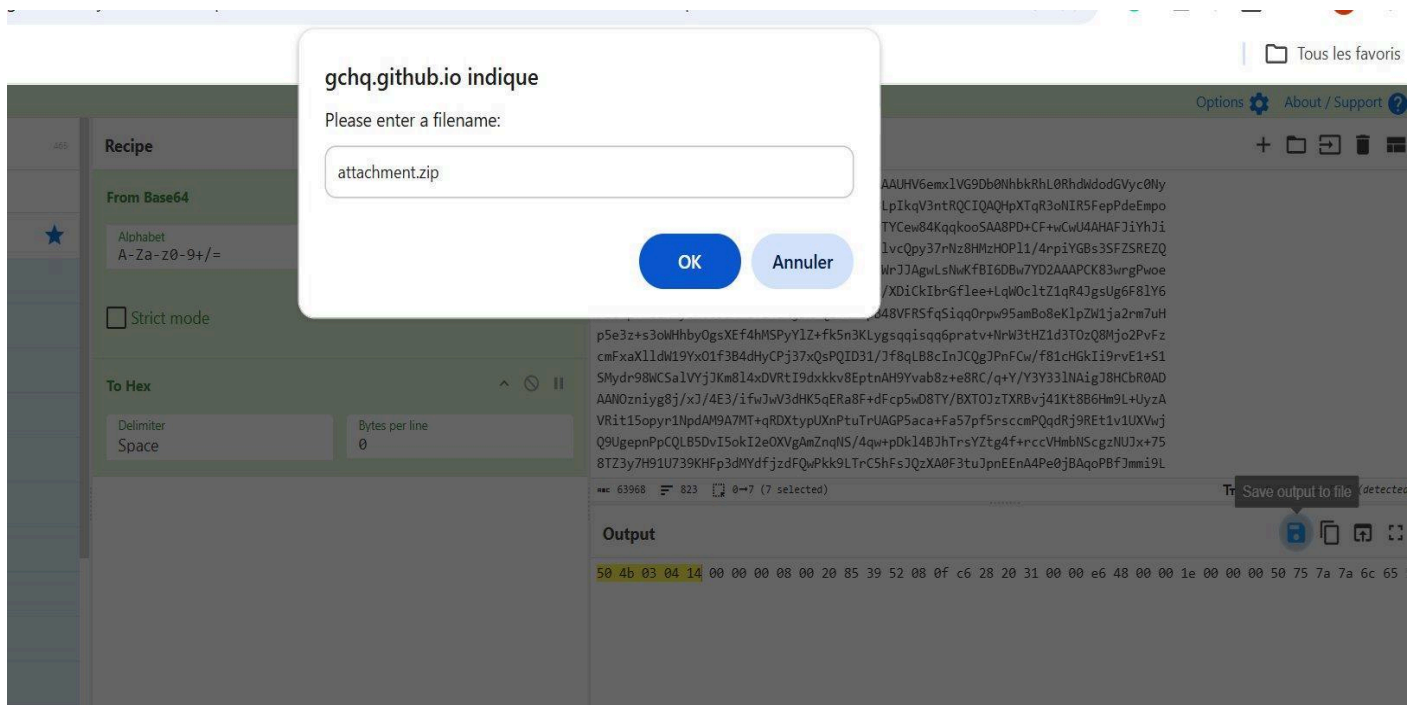
Platform	Hybrid Analysis — CrowdStrike Falcon Sandbox
Submission	attachment.zip
SHA256	97c6f491cd7901be601c2ef075c39bca5c2f51ef4eeb4524f8b5b52cc8ab62d2
File size	137 KiB
Verdict	No specific threat detected
AV detections	0 of all engines — clean
Network activity	None observed
Process behaviour	None — archive contains no executable content
Dropped files	None
Community score	0 (no community flags)
Last sandbox run	2026-02-24 14:07:48 UTC

A clean sandbox result is consistent with an archive containing social engineering documents and images rather than executable malware. The absence of AV detections does not indicate benign content — the threat is the social engineering narrative and encoded instructions, not a technical exploit. Static analysis (Section 04) was required to surface the actual threat.

5.2 Dynamic Analysis Limitations

No network traffic	No PCAP available — outbound connections, if any, cannot be verified in this investigation
No endpoint logs	No EDR telemetry or process events — no endpoint was exposed to the attachment
No user interaction	No confirmation that the recipient opened the email, extracted the archive, or engaged with any file
Stego not checked	Automated sandbox tooling does not perform steganographic analysis — DaughtersCrown.jpeg not inspected at pixel level

Figure 16 – Hybrid Analysis: attachment.zip — No Malware Detected (Social Engineering Content Confirmed)



06 THREAT INTELLIGENCE & INFRASTRUCTURE

OSINT and infrastructure analysis was performed on all IPs, domains, and mail servers associated with the campaign to characterise attacker infrastructure and support blocking decisions.

6.1 SMTP Relay — 93.99.104.210 (emkei.cz)

IP address	93.99.104.210
Hostname (PTR)	emkei.cz (Czech Republic)
ASN / Registry	RIPE NCC — Amsterdam, Netherlands
Service type	emkei.cz — publicly available anonymous email spoofing service
Abuse capability	Any user can send email from any declared From address — no authentication required
Known abuse	Widely documented in threat intelligence: phishing, harassment, BEC delivery, social engineering
Abuse contact	abuse@ripe.net +31 20 535 4444
SPF relationship	microapple.com has not authorised this IP — SPF FAIL confirmed

emkei.cz is a documented abuse platform. The attacker used it to impersonate billjobs@microapple.com without any access to microapple.com's infrastructure. This IP should be blocked at the gateway regardless of the declared sender address.

Figure 17 – WHOIS: 93.99.104.210 (RIPE NCC — emkei.cz Anonymous SMTP Relay)

[WHOIS](#)
[RDAP](#)
[DNS](#)
[Uptime](#)
[Domain Events](#)
[Website Monitoring](#)
[Login](#)

IP WHOIS Lookup

Look up registration and network information for IP addresses using WHOIS

93.99.104.210

WHOIS Information

Discover more

[Domain Management Platform](#)
[Related Domain Finder](#)
[Domain Transfer Service](#)

[Cloud storage solutions](#)
[Domain name registration services](#)
[IP address lookup tools](#)

IP Whois

NetRange:	93.0.0.0 - 93.255.255.255
CIDR:	93.0.0.0/8
NetName:	93-RTPF

6.2 Relay Domain — emkei.cz

Domain	emkei.cz
Resolved IP	114.29.236.247
Registrar	REG-INTERNET-CZ (whois.nic.cz)
Country	Czech Republic
Service purpose	Web-based anonymous fake mailer — public UI for spoofed email delivery

Threat intel	Listed on multiple abuse and reputation feeds; used in phishing, BEC, and social engineering campaigns
--------------	--

Figure 18 – WHOIS: emkei.cz (Czech Registrar — Anonymous Fake Mailer Domain)

The screenshot shows the 'who.is' WHOIS Domain Lookup interface. At the top, there's a navigation bar with links for WHOIS, RDAP, DNS, Uptime, Domain Events, Website Monitoring, and Login. The main heading is 'WHOIS Domain Lookup' with a subtext 'Look up registration details, contacts, and nameservers for any domain name'. A search bar with the placeholder 'Enter a domain name...' and a 'Search' button is present. Below this, the domain 'emkei.cz' is displayed with its WHOIS information, including the IP address '114.29.236.247'. There are buttons for 'Whois', 'RDAP', 'DNS Records', 'Uptime', 'Diagnostics', and a green 'Hide Contact Info' button. A 'Refresh Data' button is also visible. A section titled 'Discover more' lists various services like 'Graphic design services', 'WHOIS Privacy Service', 'Network monitoring services', 'RDAP API Access', 'Website Monitoring Tools', 'Domain Name Search', and 'Domain Transfer Service'. A blue box states 'The domain emkei.cz is registered. You can still try to buy it here.' The 'Registrar Information' section shows the registrar as 'REG-INTERNET-CZ' and the WHOIS Server as 'whois.nic.cz'.

6.3 Reply-To Infrastructure — pashter.com

Reply-To address	negeja3921@pashter.com
MX records	mx4.beavis99.com (195.201.18.63) mx4.beavis99.net (188.245.74.208)
MX hosting	Hetzner Online GmbH (ASN 24940) — cloud provider commonly seen in abuse cases
DMARC	No DMARC record — no anti-spoofing or reporting policy
Username pattern	negeja3921 — randomised string consistent with a disposable / burner account
Attribution link	String 'Negeja' appears in both this username and the GoodJobMajor.pdf Author field ('Pestero Negeja')
Assessment	Domain assessed as attacker-controlled — configured specifically to receive victim replies from this campaign

No DMARC policy, cloud-hosted MX on a provider commonly seen in abuse cases, and a randomised username pattern are collectively consistent with a domain registered for short-term, single-campaign use. The Hetzner infrastructure is legitimate hosting; the abuse is in how the domain is configured.

Figure 19 – MX & DMARC Analysis: pashter.com (No DMARC — Hetzner-hosted MX Servers)

SuperTool

Beta9

pashter.com

MX Lookup

mx:pashter.com

Find Problems

Solve Email Delivery Problems

mx

Microsoft Outlook.com now requires DMARC - Get SPF, DKIM and DMARC setup and maintain compliance with Delivery Center

Pref	Hostname	IP Address	TTL	
0	mx4.beavis99.com	195.201.18.63 Hetzner Online GmbH (AS24940)	60 min	Blacklist Check SMTP Test
0	mx4.beavis99.net	188.245.74.208 Hetzner Online GmbH (AS24940)	60 min	Blacklist Check SMTP Test

Test	Result	
DMARC Record Published	No DMARC Record found	More Info
DMARC Policy Not Enabled	It is recommended to use a quarantine or reject policy. To enable BLIMI, it is required to have one of these at 100%.	More Info
DNS Record Published	DNS Record found	

dns lookup

dns check

dmARC lookup

spf lookup

dns propagation

Reported by ns1.dnsowl.com on 2/24/2026 at 7:59:03 AM (UTC -6), just for you

Transcript

6.4 Infrastructure Summary

Asset	Identifier	Role	Action
SMTP Relay IP	93.99.104.210	Delivery	Block at email gateway and firewall immediately
SMTP Relay Host	emkei.cz / 114.29.236.247	Spoofing svc	Add to domain denylist — known abuse platform
Spoofed domain	microapple.com	From header	Alert on inbound — verify legitimate entity status
Reply-To domain	pashter.com	Victim capture	Block — assessed attacker-controlled
MX hosts	beavis99.com / .net	Mail receive	Monitor — Hetzner-hosted attacker infrastructure

07 SOCIAL ENGINEERING ANALYSIS

Most SOC investigations focus exclusively on technical artefacts. This section analyses the psychological design of the campaign — the specific techniques used to manufacture urgency, sustain engagement, and manufacture compliance. Understanding these mechanisms is essential for accurate threat classification and security awareness programme design.

Technique	Observed Evidence	Psychological Function
Authority impersonation	Email declared from 'Bill' at microapple.com — a technology company name designed to evoke credibility	Establishes a trusted sender persona to reduce initial scepticism before the recipient reads further

Urgency and high stakes	Hostage narrative: citizens abducted, President's daughter held, financial payment demanded. Time-implied pressure throughout	Elevates perceived consequences of inaction and compresses analytical thinking — recipient feels compelled to act rather than verify
Curiosity / puzzle hook	'Solve the puzzle I sent as an attachment for the next steps' — reframes the malicious attachment as an engaging intellectual challenge	Converts a phishing attachment into a curiosity-driven voluntary interaction. The recipient chooses to open it rather than being tricked
Cognitive dissonance cue	'Don't Trust Your Eyes' — a paradoxical instruction that warns of deception while compelling closer inspection of the very content it warns about	Primes the recipient to look harder, not less. Victims who receive this hint are more likely to rename files, remove formatting, and decode data — exactly the steps required
Multi-stage narrative consistency	Each file references the others: GoodJobMajor directs to DaughtersCrown as proof and Money.xlsx as location; Sheet1 confirms the narrative; Sheet3 provides the final answer	Sustained investment. A recipient who reaches step 3 has already accepted the premise and is psychologically committed to completing the chain
Informal register	'Lol', 'Cassshhh', theatrical punctuation — deliberately casual, personal-sounding language	Disrupts trained pattern-matching for formal phishing templates. The informal tone feels personal and non-automated, reducing suspicion
Thematic consistency	Location clue (12.8 light-min), crown image, spaceship delivery, Martian Colony — all elements reinforce a single fictional frame	Creates an internally coherent narrative that the recipient engages with on its own terms. Absurdity reduces analytical distance rather than increasing it
Gamification of discovery	Hidden file, hidden sheet, hidden text — each layer discovered feels like a reward. The recipient is incentivised to look deeper	Multi-layer reward structure sustains engagement beyond the first file. The 'puzzle' framing makes discovery feel like success rather than warning

This campaign is more sophisticated in its psychological design than in its technical execution. emkei.cz is freely available, file type masquerading is well-documented, and white-on-white Excel concealment requires no specialist knowledge. What is carefully constructed is the multi-stage reward structure, the cognitive dissonance cue, and the thematic consistency across all files — these suggest the attacker considered recipient psychology as a primary design constraint.

08 KILL CHAIN MAPPING

Observed attacker activity mapped to the Lockheed Martin Cyber Kill Chain® framework. Activity is present across four of seven phases. Installation, Command & Control, and Actions on Objectives were not reached — no malware executed and no recipient interaction was confirmed.

Phase	Observed Activity	ATT&CK Reference
1. Reconnaissance	Target email address identified prior to sending. Subject line references the recipient persona 'TheMajorOnEarth', indicating prior target research.	T1598.003 — Phishing for Information
2. Weaponization	ZIP archive built with three files, all lacking extensions. Hidden file attribute applied to GoodJobMajor. White-on-white formatting applied to Money.xlsx. Files authored via	T1027 — Obfuscated FilesT1036.008 — Masquerade File Type

	Chromium browser (Skia/PDF m90 — metadata not scrubbed).	
3. Delivery	Email sent via emkei.cz (93.99.104.210). Sender spoofed as billjobs@microapple.com. Attachment declared as application/pdf to evade ZIP-blocking filters. SPF FAIL logged but DMARC absent — delivery succeeded.	T1566.001 — SpearphishingT1584 — Infra Abuse
4. Exploitation	No technical exploit exists. Exploitation is entirely social: the recipient must voluntarily open the attachment, enable hidden items, rename files, remove Excel formatting, and decode Base64. The campaign exploits curiosity and narrative engagement.	T1585.002 — Email Account(Reply-To capture)
5. Installation	Not applicable — no malware, no persistence mechanism, no executable payload identified in any enclosed file.	N/A
6. Command & Control	Not applicable. The attacker-controlled Reply-To address (negeja3921@pashter.com) is a social communication vector, not a technical C2 channel.	N/A
7. Actions on Objectives	Not reached in this investigation — no recipient interaction observed. Intended objective assessed as financial fraud (ransom payment) and/or psychological manipulation, based on attacker narrative in Money.xlsx Sheet1.	N/A (intended: financial fraud)

09 MITRE ATT&CK® MAPPING

Techniques identified from direct observation in this investigation. Each entry includes the specific evidence observed and a corresponding detection strategy applicable at the email gateway or endpoint.

ID	Name	Tactic	Evidence	Detection
T1566.001	Spearphishing Attachment	Initial Access	Targeted email to themajoronearth@gmail.com — ZIP disguised as PDF.	Alert: attachment magic bytes mismatch vs declared MIME type. Alert: SPF FAIL + attachment combination.
T1036.008	Masquerade File Type	Defense Evasion	PuzzleToCoCanDa.pdf declared as application/pdf; magic bytes 50 4B 03 04 confirm ZIP. All 3 inner files have no extension to resist format identification.	Enforce content-aware MIME inspection at gateway. Compare file signature against declared type. Block/quarantine mismatches.
T1027	Obfuscated Files or Info	Defense Evasion	Email body Base64-encoded; hidden file attribute on GoodJobMajor; white-on-white text in Sheet1 and Sheet3; Base64 payload in hidden spreadsheet cell.	Decode Base64 email bodies for scanning. Flag hidden-attribute files in archives. DLP: Base64 pattern detection on inbound documents.
T1585.002	Establish Email Accounts	Resource Development	negeja3921@pashter.com — attacker-created disposable account; no DMARC, randomised username, Hetzner MX.	Alert: From/Reply-To domain mismatch. Check Reply-To domain age and reputation at ingest.
T1584	Compromise Infrastructure	Resource Development	emkei.cz (93.99.104.210) abused as anonymous	Maintain denylist of known anonymous SMTP relay services. Enforce DMARC reject on all organisational domains.

			SMTP relay to deliver spoofed email without access to microapple.com.	
T1598.003	Phishing for Information	Reconnaissance	Campaign designed to elicit victim reply to negeja3921@pashter.com, disclosing engagement and enabling follow-on social engineering.	Alert: From/Reply-To domain mismatch. User training: verify reply destination before responding to unsolicited email.

10 DETECTION & DEFENSIVE CONTROL GAPS

This section identifies the specific defensive control gaps that allowed this campaign to reach the inbox and that limited detection of its full scope. Each gap is mapped to the prevention control and detection rule that would have addressed it.

#	Gap	Why it was exploitable	Prevention & Detection Rule
1	SPF without DMARC	SPF FAIL was recorded but delivery succeeded because microapple.com has no DMARC policy instructing receivers to reject or quarantine on failure. SPF alone records the failure; it does not act on it.	Publish DMARC p=reject on all organisational domains. Enforce DMARC reject at the inbound gateway — reject all SPF FAIL messages from external senders impersonating internal domains.
2	Anonymous SMTP relay not blocked	emkei.cz (93.99.104.210) is a documented abuse platform. It was not present on the gateway IP denylist, requiring reactive blocking after delivery.	Maintain a proactively updated IP/domain denylist of known anonymous SMTP relay services. Subscribe to threat intel feeds that track such platforms. Block emkei.cz at perimeter.
3	From/Reply-To mismatch not alerted	The From domain (microapple.com) and Reply-To domain (pashter.com) differ — a pattern with high association with phishing and BEC. No gateway rule flagged this discrepancy.	Implement a gateway rule to alert or quarantine emails where From and Reply-To domains differ and share no organisational relationship.
4	MIME type not validated against file signature	The attachment was declared as application/pdf but contained ZIP magic bytes. The gateway accepted the declared header value without performing deep content inspection.	Enable content-aware file inspection at the gateway. Compare declared MIME type against actual file magic bytes. Block or quarantine all MIME mismatches.
5	Hidden archive file attribute not surfaced	GoodJobMajor's hidden attribute caused it to be omitted from standard extraction. No archive inspection policy enumerated all files regardless of visibility attribute.	Configure email security and endpoint tooling to enumerate all files in extracted archives including those with hidden attributes set. This should be a non-optional default.
6	Excel white-on-white content not inspected	Money.xlsx Sheet3 contained a Base64 payload concealed via white font on white background. Document content inspection evaluated visible rendered text only — not raw cell data.	Deploy document inspection tools that evaluate raw cell content and formatting metadata independently of visual rendering. Apply DLP with Base64 pattern detection on inbound XLSX.
7	Document metadata not inspected at triage	GoodJobMajor.pdf Author field 'Pestero Negeja' was not scrubbed by the attacker and was not extracted during automated triage. It was only	Add ExifTool or equivalent metadata extraction as a mandatory step in the email investigation playbook. Author, Producer, and timestamp fields can identify attacker aliases and software environments in under 10 seconds.

	discovered during manual investigation.	
--	---	--

11 RISK ASSESSMENT

11.1 Likelihood × Impact Model

Dimension	Rating	Reasoning
Likelihood	MEDIUM	Email delivered. Exploitation requires voluntary recipient action: opening the attachment, enabling hidden files, renaming files, removing Excel formatting, and decoding Base64. Layered puzzle design increases the probability that a curious non-technical user completes the chain.
Technical Impact	LOW	No malicious executable, no macro, no exploit code identified. There is no mechanism for automated system compromise. Technical impact is bounded entirely by what a human recipient chooses to do after reading.
Business Impact	MEDIUM	A recipient who replied would communicate directly with the attacker via pashter.com — enabling financial scam engagement or sustained social engineering. Attribution metadata in the PDF also constitutes an intelligence exposure.
Overall Risk	MEDIUM	Delivered successfully with confirmed multi-layer evasion. No code execution risk. Primary vector is social engineering. Risk level remains medium pending steganographic analysis of DaughtersCrown.jpeg.

11.2 CIA Impact Assessment

CIA Pillar	Impact	Basis
Confidentiality	Medium	A recipient who replied would have disclosed their engagement and potentially organisational details to the attacker via pashter.com.
Integrity	Low	No files modified, no systems accessed. No data integrity threat in the absence of confirmed recipient interaction.
Availability	Low	No ransomware or denial-of-service component detected. No availability risk to systems or services.

11.3 Confidence Level Per Finding

Finding	Confidence	Evidential Basis
Sender spoofed via anonymous SMTP relay	HIGH	SPF FAIL in Authentication-Results; emkei.cz confirmed via WHOIS reverse DNS
Attachment is ZIP, not PDF	HIGH	Magic bytes 50 4B 03 04 confirmed via CyberChef and Gary Kessler database

GoodJobMajor is a hidden PDF instruction note	HIGH	Magic bytes 25 50 44 46 confirmed; hidden attribute confirmed in Explorer; content rendered
DaughtersCrown is a JPEG image	HIGH	Magic bytes FF D8 FF E0 confirmed; ExifTool validated; rendered in Paint at 822×435px
Money.xlsx Sheet3 contains hidden Base64	HIGH	White-on-white formatting confirmed; Base64 extracted and decoded to location string
'Pestero Negeja' links PDF to Reply-To	HIGH	'Negeja' in PDF Author and Reply-To username; 'Pestero' maps to 'pashter' domain
Location reference consistent with Mars orbit	HIGH	12.8 light-min matches Mars avg distance; Sheet3 decodes to thematic Martian Colony location
pashter.com is attacker-controlled	MEDIUM	No DMARC, Hetzner-hosted MX, randomised username — strongly indicative, not forensically confirmed
DaughtersCrown contains steganographic data	LOW	Suggested by 'Don't Trust Your Eyes' hint — no steganographic analysis has been performed

12 INDICATORS OF COMPROMISE — IOC APPENDIX

All IOCs are extracted from confirmed findings. Hash values and network indicators are suitable for direct import into SIEM, EDR, and threat intelligence platforms. Attribution indicators should be used for threat hunting and actor correlation.

Type	Value	Context	Action
IP	93.99.104.210	emkei.cz SMTP relay — SPF FAIL source	Block at gateway
IP	114.29.236.247	emkei.cz domain resolved IP	Monitor / block
IP	195.201.18.63	pashter.com MX (beavis99.com) — Hetzner	Monitor
IP	188.245.74.208	pashter.com MX (beavis99.net) — Hetzner	Monitor
Domain	emkei.cz	Anonymous email spoofing service	Block at gateway
Domain	microapple.com	Spoofed From domain — not attacker-owned	Alert inbound
Domain	pashter.com	Attacker-controlled Reply-To domain	Block / denylist
Email	billjobs@microapple.com	Spoofed From — fabricated sender identity	Alert inbound
Email	negeja3921@pashter.com	Attacker's Reply-To — victim capture address	Block / denylist
SHA256	97c6f491...8ab62d2	PuzzleToCoCanDa.pdf (ZIP archive) — attachment	Add to blocklist
Filename	PuzzleToCoCanDa.pdf	Declared PDF — confirmed ZIP archive	Correlate

File	DaughtersCrown (JPEG)	ZIP content — 822×435px JPEG, no extension	Correlate
File	GoodJobMajor (PDF, hidden)	ZIP content — PDF, hidden attribute	Correlate
File	Money.xlsx	ZIP content — Base64 payload in hidden Sheet3	Correlate
String	Pestero Negeja	GoodJobMajor.pdf Author metadata — attribution	Hunt / enrich
Base64	VGhlIElhc nRpYW4gQ29sb255...	Money.xlsx Sheet3 B4 — encoded location	Correlate
Decoded	The Martian Colony, Beside Interplanetary Spaceport.	Decoded ransom location	Correlate

13 RECOMMENDATIONS

#	Priority	Action
1	HIGH	Block SMTP relay IP 93.99.104.210 and domain emkei.cz at the email gateway and perimeter firewall immediately.
2	HIGH	Block domain pashter.com at the email gateway. Flag negeja3921@pashter.com as a confirmed malicious sender address.
3	HIGH	Add SHA256 97c6f491cd7901be601c2ef075c39bca5c2f51ef4eeb4524f8b5b52cc8ab62d2 to the threat intelligence platform and EDR blocklist.
4	HIGH	Enforce a DMARC p=reject policy on the recipient organisation's domain to prevent spoofed email delivery in future campaigns.
5	MEDIUM	Submit DaughtersCrown.jpeg to steganographic tools (steghide, binwalk, zsteg) to determine whether a hidden payload is embedded in the image.
6	MEDIUM	Submit GoodJobMajor.pdf and Money.xlsx individually to VirusTotal for supplementary antivirus coverage across additional engines.
7	MEDIUM	Investigate microapple.com domain ownership to determine whether it is a legitimate entity or a lookalike domain constructed to support sender spoofing.
8	MEDIUM	Implement a From/Reply-To domain mismatch detection rule at the email gateway — alert or quarantine on mismatch for all inbound external mail.
9	LOW	Notify themajoronearth@gmail.com that this email is confirmed malicious. Advise against interacting with the attachment or replying to the sender.
10	LOW	Update the SOC investigation playbook to include ExifTool metadata extraction as a mandatory step for all document attachments. This finding took under 10 seconds and provided the strongest attribution indicator in the investigation.
11	LOW	Close this case as CONFIRMED MALICIOUS. Update status in SIEM/SOAR. Retain all artefacts and this report for future threat intelligence correlation.

14 ROOT CAUSE ANALYSIS

Root cause analysis identifies not just what the attacker did, but why each technique was available to exploit — the organisational and technical gaps that enabled each stage. This section supports systemic improvement, not blame assignment.

Root Cause	Why It Exists	Strategic Fix
SPF FAIL did not prevent delivery	The receiving organisation has no DMARC enforcement policy. SPF records record a failure; they do not instruct receivers to act on it. This is the most common misconfiguration in email authentication.	Publish DMARC p=reject on all owned domains. Treat SPF-only implementation as an incomplete configuration requiring escalation to the email security owner.
Anonymous SMTP relay reached the inbox	emkei.cz is not present on the gateway IP denylist. There is no proactive process to add known abuse platforms to the denylist without first receiving an email from them.	Subscribe to threat intel feeds that publish anonymous relay indicators. Implement a scheduled weekly denylist refresh. Add emkei.cz category to the gateway blocking policy.
ZIP attachment accepted as a PDF	The email gateway performs MIME validation based on the declared Content-Type header, not the actual file signature. Header-based MIME validation is a well-known, trivially bypassed control.	Replace header-based MIME validation with deep content inspection using file magic byte analysis at the gateway. This control gap is vendor-independent and should be treated as a configuration priority.
Hidden file in archive not detected	Standard extraction workflows do not enumerate hidden-attribute files. This affects most operating systems and email security tools by default. The gap is not unique to this organisation.	Configure email security or endpoint tooling to enumerate all files in extracted archives, treating hidden attribute flags as transparent to the inspection engine.
Document metadata not inspected at triage	ExifTool metadata extraction is not part of the standard email investigation playbook. The attribution finding ('Pestero Negeja') was only discovered through manual analysis — it would not have surfaced in automated triage.	Add metadata extraction (ExifTool or equivalent) to the email investigation playbook as a mandatory L1 triage step. The Author, Producer, and timestamp fields can identify attacker aliases in under 10 seconds.

15 LESSONS LEARNED

Lessons are drawn directly from observations and gaps identified in this investigation. They are written for a SOC Level 2+ audience and address both technical controls and analyst workflow.

#	Area	Lesson
1	File Type Validation	MIME type and file extension are attacker-controlled values and cannot be trusted as format indicators. The only reliable identifier is the file's magic bytes. Gateway inspection must compare actual signatures against declared types — this single control would have surfaced the attachment masquerade immediately.
2	Email Authentication Completeness	SPF without DMARC is an incomplete implementation. An SPF record records a failure; a DMARC p=reject policy acts on it. Organisations

		publishing only SPF create a false sense of protection — the failure is logged and the spoofed email is still delivered to the inbox.
3	Archive Hidden Attribute Enumeration	Hidden file attributes inside ZIP archives are invisible to standard extraction workflows. The most significant file in this campaign was set as hidden. Enumeration of all archive contents regardless of hidden attribute must be a non-optional default behaviour in security tooling — not an opt-in setting.
4	Document Metadata as an Investigation Step	ExifTool on GoodJobMajor.pdf produced the strongest attribution finding in this investigation in under 10 seconds. Metadata extraction is absent from most SOC L1 playbooks. Author, Producer, creation time, and software fields can identify the attacker's operating environment and aliases. It should be a mandatory triage step for all document attachments.
5	Excel as a Data Concealment Vector	White-on-white cell formatting is trivially applied and highly effective against visual inspection. Spreadsheets can conceal data in hidden sheets, conditional formatting, merged cells, and cell colours that match the background. Document inspection tools must evaluate raw cell data — not rendered output — to detect these techniques.
6	Layered Obfuscation Requires Layered Defence	This campaign used six distinct evasion techniques. No single control addressed all of them. Perimeter email filtering, content-aware file inspection, archive enumeration, endpoint behavioural detection, and user awareness training must each be present — a gap in any layer creates an exploitable opportunity that the others cannot compensate for.
7	Social Engineering Deserves Formal Documentation	The psychological design of this campaign — multi-stage reward structure, cognitive dissonance cue, narrative consistency — is more sophisticated than its technical execution. Documenting social engineering techniques alongside technical findings improves threat classification accuracy and directly informs the content of user awareness training programmes.
8	Document Metadata Scrubbing is an Attacker Discipline	The attacker's failure to scrub the PDF Author field was an operational security mistake that provided the strongest attribution link in the investigation. This should be included in threat actor TTP profiling: actors using browser-generated PDFs or commodity tools routinely leave identity artefacts. Analysts should always check.

16 CONFIDENCE & INVESTIGATION LIMITATIONS

Professional investigation reports explicitly document what evidence was unavailable and how those gaps affect analytical confidence. This section distinguishes confirmed findings from assessed findings and identifies open items requiring further work.

16.1 Evidence Available for This Investigation

Email source (.eml)	Complete — full header chain, Authentication-Results, ARC headers, encoded body and attachment
Email body	Complete — Base64 decoded via CyberChef; full text extracted and analysed
Attachment	Complete — Base64 decoded, saved as ZIP, all 3 files extracted in Windows VM

File metadata	Complete — ExifTool run on all files; attribution metadata found in GoodJobMajor.pdf
File signatures	Complete — HxD hex analysis and Gary Kessler database cross-reference for all files
Sandbox report	Complete — Hybrid Analysis full report reviewed; no malware confirmed
Infrastructure	Complete — WHOIS, DNS MX, and DMARC lookups performed on all relevant domains and IPs

16.2 Evidence Not Available

Network traffic	No PCAP or DNS logs available — cannot verify whether the recipient's endpoint made any outbound connections after email receipt
Endpoint telemetry	No EDR data, process logs, or filesystem events — cannot confirm whether any file was opened on a real device
User interaction	No confirmation of whether the recipient opened the email, extracted the archive, or engaged with any enclosed file
Steganographic analysis	DaughtersCrown.jpeg has not been analysed with dedicated stego tooling — the 'Don't Trust Your Eyes' hint cannot be fully evaluated
Domain registration dates	Ownership and registration age of pashter.com and microapple.com were not confirmed — would refine attribution confidence
Per-file VirusTotal	Each individual ZIP file was not submitted to VirusTotal — supplementary AV coverage gap remains

16.3 Confidence Statement

All HIGH confidence findings are based on direct forensic observation: magic byte analysis, header inspection, rendered file content, and metadata extraction. No inference is presented as confirmed. MEDIUM confidence findings are assessed from strong circumstantial evidence. The single LOW confidence finding — potential steganographic content in DaughtersCrown.jpeg — is explicitly flagged as unverified and requires dedicated steganographic tooling before confidence can be raised.